山东大学
网络空间安全学院

《网络安全》
实验报告

学生姓名	江李阳 (202400460042) 王健一 (202400460037) 邱泽辉 (202400460046)
指导教师	郭山清
学院	网络空间安全学院
专业班级	密码科学与技术 2024 级一班
完成时间	2026 年 10 月 23 日

1 实验目标

- 深入理解 TCP 协议的基本原理和　作　式；
- 了解主机探测和端　扫描的原理，掌握　络资产探测的基本技能；
- 理解 TCP 的报　结构，包括协议头中各个参数的作　和含义；
- 加深对 TCP 协议安全缺陷的理解，学习常　的攻击　式和防御措施；
- 实战演练 SYN Flood 攻击、TCP 连接重置及 TCP 会话劫持，了解它们的原理和危害。

2 实验原理

2.1 资产探测与端口扫描

2.1.1 TCP 端口扫描

TCP 端口扫描包括全连接扫描和半连接扫描，其中全连接扫描指 attacker 尝试与 victim/待扫描主机建立 TCP 连接，如果 attacker 收到 victim 发来的 SYN+ACK，说明该端口开放，否则如果收到 RST 说明该端口关闭，通过这种方式，attacker 就能确认 victim 上哪些端口是开放的，哪些是关闭的。全连接扫描与半连接扫描的区别在于 victim 恢复 SYN+ACK 后，前者将恢复一个 ACK，两者将完成 TCP3 次握手，建立起真正的 TCP 连接，而后者只是回复一个 RST，两台主机间并不会建立真正的 TCP 连接。相比之下，全连接扫描准确率更高，但效率较低，且完整的连接过程会留下明显的日志记录；而半连接扫描的扫描速度更快，具有一定的隐蔽性。更多 TCP 端口扫描方式包括：

- TCP Maimon 扫描：attacker 向目标端口发送同时设置 FIN 和 ACK 标志的错误数据包，如果端口开放，将忽略这类非法数据包；如果端口关闭，则会响应 RST 报文。
- TCP NULL 扫描：attacker 发送一个不带任何 TCP 标志的数据包，即所有位都设为 0，没有 SYN、ACK、FIN 等任何标志。这类数据包同样不是正常的 TCP 数据包，因此如果端口是关闭的，victim 通常会回复一个 RST 数据包；如果端口是开放的，或者被过滤，victim 不会做任何响应。
- TCP FIN 扫描：attacker 发送一个只设置了 FIN 标志位的 TCP 数据包。FIN 通常用于正常 TCP 连接终止，但如果在连接初始化阶段发送就不是正常 TCP 数据包了。类似 NULL 扫描，如果端口是关闭的，victim 将回复一个 RST 数据包，；如果没有响应或一个明显的 ICMP 错误响应，一般意味着端口开放或被过滤。

- TCP Xmas 扫描：在数据包中设置多个标志位 (FIN,PSH,URG)，如果端口关闭，则会回复 RST；如果端口开放或被过滤，则可能不回复。

下面具体介绍两种隐蔽扫描方式：

- idlesan(空闲扫描)：借助一台空闲主机 C，具体过程如下：
  - (1)attacker 向空闲主机 C 发送 ICMP 请求，得到 C 的 ICMP 响应，并记录下对应的 `IPID`=n;
  - (2)attacker 向 victim 待扫描端口发送 TCP 的 SYN 数据包，其中源 IP 为主机 C 的 IP，端口为待探测端口。
  - (3i) 如果 victim 对应端口开放，将向 C 回复一个 SYN+ACK。C 直接收到 SYN+ACK 将会将其视为非法数据包，直接回复一个 RST，此时 `IPID`=n+1；
  - (3ii) 如果 victim 对应端口关闭，则将回复一个 RST，C 收到后不做响应，此时 C 的 `IPID` 还是 n。
  - (4)attacker 向空闲主机发送 ICMP 请求，得到 C 的 ICMP 响应和对应 `IPID`，如果此时收到的 C 的 `IPID` 值为 n+2，则对应上面 (3i) 的情况，对应端口开防；如果 `IPID` 值为 $n+1$，则对应上面 (3ii) 的情况，说明对应待探测端口关闭。

  这种方法的优点是在扫描时不泄露 attacker 自身的信息，只借助空闲主机 C 的返回情况来判断待扫描 victim 端口的情况。但这种方法也有非常大的缺点，这种方法严重依赖空闲主机 C 的 `IPID` 参数全局自增的特点，而由于这个参数实际并没有什么含义，目前绝大多数终端的 IPID 采用随机数或基于哈希函数来计算 `IPID` 值，attacker 难以实现预测。其次，该方法还要求空闲主机 C 必须是完全空闲的，否则当 (4) 发送 ICMP 后收到的 `IPID` 值为 n+2 时，实际 attacker 并不能确认使得 C 上一步 `IPID` 自增为 n+1 的到底是 victim 回复的 SYN+ACK 导致的，还是其他主机与 C 通信导致的，这就导致了现象无法确定结果，进而造成扫描准确率下降。

- TCP RST 速率限制：该方法基于 TCP RST 速率的隐蔽扫描方法，利用了操作系统的 TCP 协议栈在短时间内能够发送的 RST 报文数量有限这一固有特性，具体来说：
  - (1)attacker 向 victim 待探测端口发送大量 SYN 数据包，其中源 IP 为主机 C 的 IP，目的端口为待扫描端口。

- (2i) 如果 victim 对应的端口开放，则 victim 会向 C 发送大量 SYN+ACK 报文，此时 C 针对这些非法报文将回复大量 RST 报文并最终达到 RST 速率限制；
- (2ii) 如果 victim 对应的端口关闭，则 victim 会向 C 发送大量的 RST 报文，C 将忽略这些 RST 报文不做回复，因而没有达到 RST 速率限制。
- (3)attacker 向 C 发送 ICMP NULL，如果 C 能回复 RST 报文，说明它没有达到 RST 速率限制，对应情况 (2ii) 说明 victim 上端口关闭；反之如果 C 不能回复 RST 报文，说明它达到了 RST 速率限制，对应情况 (2i)，说明 victim 上对应端口开放。

2.1.2 资产探测

包括设备与协议的指纹识别和操作系统的指纹识别。

- 设备与协议指纹：不同网络设备、协议实现和软件应用在网络连接中会表现出细微的差别，这些在通信连接中表现出来的独特特性被称为设备、系统或软件的指纹。
- 操作系统的指纹：
  - 被动指纹：如观察目标发送的 SYN/SYN-ACK/RST 等包中的 TTL、Windows Size、IPID、TCP 选项等，不同操作系统中的初始 TTL 值设置并不相同：Windows 系统中通常为 128，UNIX 类系统一般为 64；通过观察 HTTP headers、Cookie 特征、TLS 指纹、DNS 查询模式等组合来推断操作系统或应用。
  - 主动指纹：（TCP/IP 主动栈探测）向目标发送一系列特殊构造的 TCP/IP 包，根据包的细微差异匹配指纹库，Nmap 就是一个著名的实现例子；连接目标服务端口 (如 SSH、HTTP、SMB、FTP 等)，读取 banner 或协议特性来识别操作系统或发行版倾向，这种方法简单但容易被管理员修改或禁用横幅。

3 实验设置

3.1 实验分工与配置说明

本组采用分工协作的方式完成本次实验。各成员在自己的环境中独立完成实验、记录终端输出和抓包截图，再按照实验分工汇总整理报告。由于虚拟机网卡连接、网卡名称、

地址分配和实验推进顺序可能存在差异，实际配置并不严格与实验指导书逐项相同，但保持拓扑关系和实验现象满足要求。具体分工如下:

表 1 本组实验报告撰写分工

成员	正文负责任务	说明
江李阳	实验一：1	
王健一	实验二：2	
邱泽辉	实验一：3	

4 实验讨论

5 参考资料

A 附录：关键代码